

Information Classification Policy

FortisAid Health Technologies

Policy Number: FTAID-POL-002

Version 1.0 | Effective: 18 Feb 2026

Document Control Page

Field	Details
Policy Title	Information Classification Policy
Policy Number	FTAID-POL-002
Author	Information Security Manager
Policy Owner	Chief Information Security Officer
Reviewer	Clinical Systems Director
Approver	Chief Operating Officer
Version	1.0
Effective Date	18 February 2026
Current Review Date	18 February 2026
Next Review Date	18 February 2027
ISO 27002:2022 Domain	Organisational Controls
ISO 27002:2022 Sub-domain	Classification of information; Labelling of information; Privacy and protection of PII
ISO 27002:2022 Control	5.12, 5.13, 5.34
Related Policies	Data Protection and Privacy Policy; Access Control Policy; Acceptable Use Policy
Approval Status	Approved

Approval Evidence

Approver: Chief Operating Officer

X

Chief Operating Officer

1. Purpose and Scope

Purpose:

To define how FortisAid classifies, labels, and handles information so that patient health information (PHI), personally identifiable information (PII), and clinical/operational data receive protection proportional to risk, supporting safe care delivery and regulatory compliance.

Scope:

This policy applies to all FortisAid employees, clinicians, contractors, interns, agency staff, and third parties who create, access, store, process, transmit, or dispose of FortisAid information in any form (digital, paper, verbal, image/audio, backups, and logs), across all systems including cloud services, endpoints, and clinical platforms.

FortisAid Context:

FortisAid is a UK based healthcare technology organisation delivering secure digital health services, remote patient monitoring, and clinical data analytics solutions to healthcare providers and private medical partners. The organisation processes large volumes of sensitive patient information including electronic health records, diagnostic images, laboratory results, and clinician documentation. FortisAid also manages employee records, supplier contracts, and operational system data. Operations are primarily cloud hosted, with secure remote access provided to clinicians, administrative staff, and authorised partners. Information security is critical to patient safety, regulatory compliance, operational continuity, and organisational trust.

2. ISO 27002:2022 Alignment

ISO Domain	ISO Sub-domain	Control Number	How this policy addresses it
Organisational Controls	Classification of information	5.12	Defines a FortisAid classification scheme and assigns ownership so controls are applied based on confidentiality, integrity, and availability needs.
Organisational Controls	Labelling of information	5.13	Requires labels/metadata for documents, datasets, emails, and records so users and systems can enforce handling rules.
Organisational Controls	Privacy and protection of PII	5.34	Ensures PHI/PII is treated as Highly Sensitive, with lawful processing, access restrictions, and handling rules aligned to privacy obligations.

3. Threats and Key Risks (Healthcare Context)

Threats:

- Phishing and credential theft leading to unauthorised access to PHI and clinical systems.
- Ransomware or malware causing data encryption, service disruption, and unsafe clinical downtime.

Key Risks to FortisAid:

- PHI/PII breach causing patient harm, regulatory investigation/fines, and loss of trust.
- Clinical service disruption impacting patient safety and operational continuity.

4. Policy Statements / Requirements

4.1 Classification Scheme and Ownership

- FortisAid will maintain a standard classification scheme: Public, Internal, Confidential, and Highly Sensitive (PHI/PII).
- Information Asset Owners must assign a classification at creation (or at first receipt) and review classification at least annually or on material change.

4.2 Labelling and Handling Requirements

- All Confidential and Highly Sensitive information must be clearly labelled in documents and datasets; digital assets must include metadata labels where supported.
- Highly Sensitive (PHI/PII) must not be shared via personal email, consumer messaging apps, or unmanaged file-sharing services; approved secure channels must be used.

4.3 Storage, Transmission, and Disposal Controls

- Confidential and Highly Sensitive information must be stored only in FortisAid-approved systems with access controls; local storage requires device encryption and approval.
- Highly Sensitive information must be encrypted in transit and at rest using approved cryptographic mechanisms; backups must inherit the same classification and protections.

5. Roles and Responsibilities

Role	Responsibilities
Chief Executive Officer / Chief Operating Officer	Approves policy; sponsors classification programme; approves high-risk exceptions.
Chief Information Security Officer (CISO)	Policy owner; approves exceptions; provides oversight.
Information Security Manager (ISM)	Maintains classification scheme and labels; coordinates audits and remediation.
Clinical Systems Director	Validates classification/handling for clinical systems (EHR, imaging, labs).
Data Protection Officer (DPO)	Ensures PHI/PII handling meets privacy obligations; advises on breach impact.
Information Asset Owners	Classify and label assets/datasets; enforce handling rules; approve access as needed.
Security Operations Lead	Monitors for misclassification, unauthorised access, and leakage; escalates incidents.
All Employees and Contractors	Apply labels/handling rules; report misclassification or data loss immediately.
Suppliers / Third Parties	Comply with contractual classification requirements; notify FortisAid of incidents.

6. Compliance and Enforcement

Monitoring Activities:

- Quarterly: Review labels on high-risk repositories (EHR exports, shared drives, collaboration spaces) - Owner: Information Security Manager - Evidence: audit checklist and findings log.
- Monthly: DLP/SIEM review for attempted exfiltration of Highly Sensitive (PHI/PII) - Owner: Security Operations Lead - Evidence: alert/report export.

Non-Compliance: Violations may result in disciplinary action and/or reporting where required.

Exceptions: Must be approved by the CISO in writing and reviewed annually.

7. Training and Awareness

- Mandatory completion of information classification and data handling training within 30 days of joining FortisAid.
- Annual refresher training for all staff; targeted refreshers after major incidents or policy updates.

8. Review and Revision

- This policy will be reviewed annually or following significant incidents or regulatory changes.
- Next scheduled review: **18 February 2027**.

References

- ISO/IEC 27002:2022
- UK GDPR / Data Protection Act 2018
- HIPAA Security Rule
- NHS Data Security and Protection Toolkit